

As linhas de base de segurança da rede descrevem um conjunto de configurações e controles mínimos de segurança para uma rede. Geralmente, as linhas de base abrangem áreas como configurações de firewall, configurações de segurança de roteadores e switches, configurações de wireless access points e protocolos de segurança para dispositivos de rede. As linhas de base oferecem um ponto de partida para o processo de hardening. Elas garantem que os serviços desnecessários sejam desativados, as senhas padrão sejam alteradas, os protocolos seguros sejam aplicados, e incluem muitas outras configurações. As ferramentas em conformidade com o Security Content Automation Protocol (SCAP) podem automatizar a avaliação das configurações de segurança de acordo com uma linha de base predefinida.

Objetivos abordados no exame:

- 4.1 Considerando determinado cenário, aplicar técnicas de segurança comuns aos recursos de computação.
- 4.5 Considerando determinado cenário, modificar os recursos empresariais para aumentar a segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma [[baseline segura]] é um conjunto de configurações e ajustes padrão para dispositivos de rede, softwares, aplicação de patches e atualizações, controles de acesso, registro de logs, monitoramento, políticas de senha, criptografia, proteção de endpoints, entre outros. As linhas de base seguras melhoram a segurança, a capacidade de gerenciamento e a eficiência operacional da tecnologia da informação, estabelecendo regras e procedimentos uniformes e centralizados em relação à configuração e proteção do ambiente.

Obs: uma nota de resumo sobre o que é e um exemplo de funcionamento bem simples dele está em [[O que é uma baseline segura ?]].

Os Benchmarks do Center for Internet Security (CIS) (<https://www.cisecurity.org/>) são um recurso importante para as melhores práticas de configuração segura. O CIS é reconhecido mundialmente por publicar e manter guias de boas práticas para proteção de sistemas e dados de TI. Os benchmarks do CIS (<https://www.cisecurity.org/cis-benchmarks>) abrangem vários domínios, como redes, sistemas operacionais e aplicativos, e são constantemente atualizados em resposta à evolução dos riscos. Por exemplo, existem benchmarks para cumprir estruturas de TI e programas de conformidade, como PCI DSS, NIST 800-53, SOX e ISO 27000. Há também benchmarks com foco no produto, por exemplo, para Windows Desktop, Windows Server, macOS, Linux, Cisco, navegadores web, servidores web, servidores de banco de dados e e-mail e VMware ESXi. Os guias de implementação técnica de segurança (STIGs) (<https://public.cyber.mil/stigs/>) são uma linha de base segura específica desenvolvida pela Defense Information Systems

Agency (DISA) (<https://disa.mil/>) para o Departamento de Defesa dos EUA. Tal como os benchmarks do CIS, os STIGs estabelecem um conjunto padronizado de configurações e controles de segurança criados especificamente para a infraestrutura de TI do Departamento de Defesa.

Várias ferramentas e tecnologias estão disponíveis para ajudar a gerenciar, implantar e avaliar a conformidade com as linhas de base seguras estabelecidas. As ferramentas de gerenciamento de configuração, como Puppet (<https://www.puppet.com/>), Chef (<https://www.chef.io/>), Ansible (<https://www.ansible.com/>) e Group Policy da Microsoft, permitem que as organizações automatizem a implantação de configurações de linha de base seguras em diversos sistemas. Essas ferramentas ajudam a reforçar a consistência e a detectar e corrigir desvios em relação à linha de base estabelecida. Para monitorar a conformidade, ferramentas compatíveis com o Security Content Automation Protocol (SCAP), como o OpenSCAP (<https://www.open-scap.org/>), podem avaliar e verificar a aderência do sistema à baseline. Além disso, o CIS disponibiliza a ferramenta CIS-CAT Pro (<https://www.cisecurity.org/cybersecurity-tools/cis-cat-pro>), desenvolvida para avaliar as configurações dos sistemas em relação aos benchmarks de baseline segura do próprio CIS. O SCAP Compliance Checker (SCC) (<https://public.cyber.mil/stigs/scap/>) é uma ferramenta mantida pela DISA utilizada para medir a conformidade com as baselines STIG.

Conceitos de hardening

Equipamentos de rede, softwares e sistemas operacionais usam as configurações padrão do desenvolvedor ou do fabricante, que tentam equilibrar a facilidade de uso com a segurança. Elas, porém, são um alvo convidativo para os invasores, pois geralmente incluem credenciais bem documentadas, permitem senhas simples, usam protocolos inseguros e muitas outras configurações problemáticas. Ao manter essas configurações padrão, as organizações aumentam as chances de ataques cibernéticos bem-sucedidos. Portanto, é fundamental alterar essas configurações padrão para aumentar a segurança.

[[Hardening]] descreve os métodos para aprimorar a segurança de um dispositivo por meio da alteração de sua configuração padrão, frequentemente adotando as recomendações presentes em baselines seguras publicadas.

Switches e roteadores

Veja a seguir exemplos de alterações nas configurações padrão para aumentar a segurança de switches e roteadores:

- **Altere as credenciais padrão**, que são bem documentadas e representam um risco significativo à segurança.
- **Desative serviços e interfaces desnecessários** em um switch ou roteador. Nem todos os serviços ou interfaces são necessários. Por exemplo, serviços como HTTP ou Telnet devem ser evitados.
- **Utilize protocolos de gerenciamento seguros**, como SSH em vez de Telnet ou HTTPS em vez de HTTP.
- **Implemente listas de controle de acesso (ACLs)** para restringir o acesso ao roteador ou switch apenas aos dispositivos e redes necessários.
- **Ative o registro e o monitoramento de logs** para ajudar a identificar problemas como falhas repetidas de login, alterações de configuração, entre outros.
- A **configuração de segurança da porta** ajuda a limitar os dispositivos que podem se conectar a uma porta de switch para impedir o acesso não autorizado.
- As **políticas de senha forte** ajudam a reduzir o risco de ataques de senha.

- **Mantenha os equipamentos fisicamente** seguros, como em uma sala trancada, para impedir o acesso físico não autorizado.

Hardware de servidor e sistemas operacionais

Veja a seguir exemplos de alterações nas configurações padrão para aumentar a segurança de servidores:

- **Modifique as credenciais padrão** para impedir o acesso não autorizado, do mesmo modo que nos dispositivos de rede.
- **Desative serviços desnecessários** para reduzir a superfície de ataque do servidor. Cada serviço em execução em um servidor é um potencial ponto de entrada para um invasor.
- **Aplique patches e atualizações de segurança do software regularmente** para corrigir vulnerabilidades conhecidas e fornecer melhorias de segurança. O gerenciamento automatizado de patches garante que esse processo seja consistente e oportuno.
- O **princípio do privilégio mínimo** limita cada usuário ao mínimo de privilégio necessário para executar a sua função de forma a reduzir o impacto caso a conta seja comprometida.
- **Use firewalls e sistemas de detecção de intrusão (IDS)** para ajudar a bloquear ou alertar sobre atividades mal-intencionadas.
- Uma **configuração segura** dos servidores deve usar configurações de referência, como as fornecidas pelos CIS ou STIG.
- **Controles de acesso fortes** incluem políticas de senhas fortes, autenticação multifator (Multifactor Authentication, MFA) e gerenciamento de acesso privilegiado (Privileged Access Management, PAM).
- **Ative o armazenamento de registros e o monitoramento** para ajudar a identificar problemas como falhas repetidas de login, alterações de configuração, entre outros, o que também traz benefícios ao equipamento de rede.
- **Use soluções antivírus e antimalware para** detectar e colocar o malware em quarentena automaticamente.
- A **segurança física** de racks de equipamentos de servidor, salas de servidores ou datacenters impede o acesso não autorizado.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As considerações sobre a instalação da rede wireless referem-se aos fatores que garantem a boa disponibilidade de access points Wi-Fi autorizados. Uma rede com cobertura irregular é vulnerável a ataques maliciosos e de evil twin.

Nota:

A banda de 5 GHz tem mais espaço para configurar canais não sobrepostos. Observe também que um WAP pode usar canais vinculados para melhorar a largura de banda, mas isso aumenta os riscos de interferência.

Posicionamento de wireless access points (WAP)

Uma rede sem fio baseada em infraestrutura compreende um ou mais wireless access points, cada um conectado a uma rede com fio. Os [[pontos de acesso]] encaminham o tráfego de e para a rede comutada cabeada. Cada WAP (Wireless Access Point) é identificado por seu endereço MAC, também conhecido como seu identificador de conjunto de serviços básicos (Basic Service Set Identifier, BSSID). Cada rede sem fio é identificada por seu nome ou [[identificador de conjunto de serviço (SSID)]]].

Redes sem fio podem operar nas faixas de frequência de 2,4 GHz, 5 GHz ou 6 GHz. Cada banda de rádio é dividida em vários canais, e cada WAP deve ser configurado para usar um canal específico. Por razões de desempenho, os canais escolhidos devem ficar o mais distantes possível para reduzir a interferência.

Levantamentos de local e mapas de incidência

Os fatores de cobertura e interferência significam que os WAPs devem ser posicionados e configurados para cobrir toda a área com a menor sobreposição possível. Uma [[avaliação de site (site survey)]] é utilizada para medir a intensidade do sinal e o uso do canal em toda a área a ser coberta. Um levantamento do local começa com um mapa arquitetônico do local, com os elementos que possam causar interferência de fundo devidamente marcados. Esses elementos incluem paredes sólidas, superfícies reflexivas, motores, fornos de micro-ondas e assim por diante. Um notebook ou dispositivo móvel com o Wi-Fi habilitado e o software analisador de Wi-Fi instalado realiza o levantamento. O analisador de Wi-Fi registra informações sobre o sinal obtido em pontos simetricamente espaçados à medida que a pessoa se move pela área.

Figura 1. Exemplo de resultado da ferramenta Wi-Fi Scanner da Lizard Systems.



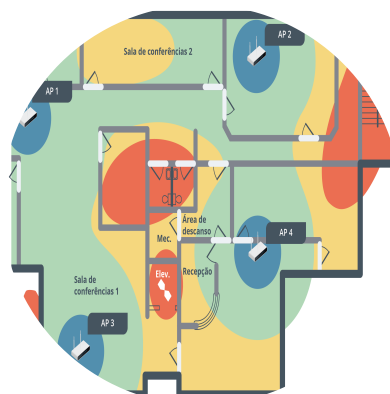
Captura de tela cortesia da Lizard Systems.

Descrição

As três abas no canto superior esquerdo são: scanner (selecionada), conexão atual e estatísticas sem fio. O painel esquerdo, intitulado Filtros, possui quatro botões expansíveis: qualidade, modo de rede, segurança e banda. A tabela no canto superior direito lista dados incluindo: gráfico, nome da rede (SSID), endereço MAC, fabricante, intensidade do sinal, qualidade do sinal, frequência, detalhes da rede, taxa alcançável e taxa máxima. A aba gráficos está selecionada no painel inferior direito. O menu suspenso de seleção de gráfico está definido para intensidade do sinal: decibel-milivatts. O gráfico de linhas abaixo plota a intensidade do sinal em decibel-milivatts ao longo do tempo.

Essas leituras são combinadas e analisadas para produzir um [[mapa de calor]], indicando onde o sinal está forte (verde/azul) ou fraco (vermelho), além de mostrar quais canais estão em uso e como se sobrepõem. Esses dados são então usados para otimizar o projeto, ajustando a potência de transmissão para reduzir a área de cobertura de um WAP, alterando o canal em um WAP, adicionando um novo WAP ou movendo fisicamente um WAP para um novo local.

Figura 2. Ilustração de um mapa de incidência



Descrição

O painel esquerdo, intitulado Banda ou Nome, exibe a caixa de seleção 802.11an marcada. As quatro subcaixas de seleção a seguir também estão marcadas. As subcaixas de seleção são: virtual AP hash 1 (5 GHz), virtual AP hash 2 (5 GHz), virtual AP hash 3 (5 GHz) e virtual AP hash 4 (5 GHz). O painel direito exibe um mapa de calor de regiões compostas por sala de reuniões 1, elevador, recepção, área mecânica, área de fundos, arquivos e sala de reuniões 2. Os quatro destaques na região são: virtual AP hash 1 (5 GHz), virtual AP hash 2 (5 GHz), virtual AP hash 3 (5 GHz) e virtual AP hash 4 (5 GHz).

Nota:

Exemplo de mapa de calor de um espaço de escritório com quatro pontos de acesso. As cores são utilizadas para indicar a intensidade do sinal proveniente dos pontos de acesso, conforme o seguinte esquema: azul indica sinal forte, verde indica bom sinal, amarelo indica sinal razoável e vermelho indica sinal fraco ou ausência de sinal. A intensidade do sinal é influenciada pela distância em relação ao ponto de acesso e por obstruções, como paredes de metal, pedra ou estruturas metálicas, como elevadores.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Além do projeto do local, uma rede sem fio deve ser configurada com definições de segurança. Sem criptografia, qualquer pessoa pode interceptar e ler os pacotes que passam pela rede sem fio, desde que estejam dentro do seu alcance. As escolhas de segurança são determinadas pelo suporte do dispositivo aos vários padrões de segurança de Wi-Fi, pelo tipo de infraestrutura de autenticação e pela finalidade da WLAN. O padrão de segurança determina quais protocolos criptográficos são suportados, os meios de gerar a chave de criptografia e os métodos disponíveis para autenticar estações wireless quando tentam ingressar (ou se associar) à rede.

A primeira versão do [[Wi-Fi Protected Access (WPA)]] foi criada para corrigir vulnerabilidades críticas presentes no padrão anterior de [[Wired Equivalent Privacy (WEP)]] . Assim como o WEP, a versão 1 do WPA utiliza o cifrador de fluxo RC4, mas adiciona um mecanismo chamado [[Temporal Key Integrity Protocol (TKIP)]] para reforçar sua segurança.

Figura 1. Configuração de um access point TP-LINK SOHO com configurações de criptografia e autenticação wireless. Neste exemplo, a banda de 2,4 GHz permite conexões legadas com segurança WPA2-Personal, enquanto a rede de 5 GHz é para dispositivos compatíveis com 802.11ax (Wi-Fi 6) usando autenticação WPA3-SAE.

Captura de tela usada com permissão da TP-Link Technologies.

Descrição

As configurações são as seguintes: OFDMA está ativado. Smart Connect não está ativado. 2,4 GHz está ativado. Nome da rede (SSID): TP-Link_22DD. Segurança: WPA/WPA2-Personal. Versão: WPA2-PSK. Criptografia: AES. Senha: tplinkpassword. Potência de transmissão: alta. Largura do canal: automático. Canal: automático. Modo: 802.11b/g/n misto. 5 GHz está ativado. Nome da rede (SSID): TP-Link_22DD_5G. Segurança: WPA2/WPA3-Personal. Versão: WPA3-SAE. Senha: tplinkpassword. Potência de transmissão: alta. Largura do canal: automático. Canal: automático. Modo: 802.11ax apenas.

Configuração Wi-Fi protegida (WPS)

Como a configuração segura de um ponto de acesso é relativamente complexa para consumidores residenciais, os fabricantes desenvolveram um sistema para automatizar esse processo chamado [[Wi-Fi Protected Setup (WPS)]]. Para usar o WPS, o access point e a estação wireless (dispositivo cliente) devem ser compatíveis com WPS. Em geral, esses dispositivos terão um botão. Pressioná-los simultaneamente no access point e no adaptador associará os dispositivos usando um PIN e, em seguida, associará o adaptador ao ponto de acesso usando WPA2. O sistema gera um SSID e PSK aleatórios. Se os dispositivos não suportarem o método do botão, o PIN (impresso no WAP) poderá ser inserido manualmente.

Infelizmente, o WPS é vulnerável a um ataque de força bruta. Embora o PIN tenha oito caracteres, um dígito é para soma de verificação e o restante é verificado como dois PINs separados de quatro e três caracteres. Esses PINs separados são muitas ordens de magnitude menos resistentes à força bruta, normalmente exigindo apenas algumas horas para desvendar. Em alguns modelos, desativar o WPS por meio da interface de administração não desativa o protocolo ou não há opção para desativá-lo. Alguns APs podem bloquear um intruso se um ataque de força bruta for detectado, mas, em alguns casos, o ataque pode ser retomado quando o período de bloqueio expirar.

Para combater isso, o período de bloqueio pode ser aumentado. No entanto, isso pode deixar os APs vulneráveis a um ataque de negação de serviço (DoS). Ao provisionar um WAP, é essencial verificar quais etapas o fabricante tomou para tornar sua implementação de WPS segura e usar o nível de firmware do dispositivo necessário identificado como seguro.

O método Easy Connect, anunciado juntamente com o WPA3, destina-se a substituir o WPS como um método de configuração segura de dispositivos clientes com as informações necessárias para acessar uma rede Wi-Fi. Easy Connect é o nome comercial do protocolo de provisionamento de dispositivos (Device Provisioning Protocol, DPP).

Cada dispositivo participante deve ser configurado com um par de chaves pública/privada. O Easy Connect usa códigos de resposta rápida (Quick Response, QR) ou tags de comunicação a curta distância (Near-Field Communication, NFC) para comunicar a chave pública de cada dispositivo. Um smartphone é registrado como um aplicativo configurador Easy Connect e associado ao WAP usando seu código QR. Cada dispositivo cliente pode, então, ser associado por meio da leitura de seu QR code ou tag NFC no aplicativo de configuração. Além de solucionar os problemas de segurança relacionados ao WPS, esse método oferece uma forma simples de configurar dispositivos de Internet das Coisas (IoT) sem interface gráfica ("headless") com conectividade Wi-Fi.

Acesso Wi-Fi protegido 3 (WPA3)

Nem o WEP nem a versão original do WPA são considerados seguros o suficiente para uso contínuo. O WPA2 utiliza o Advanced Encryption Standard (AES), implementado no modo Counter Mode com o protocolo Cipher Block Chaining Message Authentication Code (CCM). O AES substitui o RC4 e o CCM substitui o TKIP. O CCMP fornece criptografia autenticada, que é projetada para dificultar os ataques de repetição.

As fraquezas encontradas no WPA2 levaram à substituição pretendida pelo WPA3. Os principais recursos do WPA3 são:

- **[[Simultaneous Authentication of Equals (SAE)]]**: substitui o protocolo de troca de chave pré-compartilhada (PSK) do WPA2, garantindo que um invasor não possa interceptar a senha do Wi-Fi mesmo capturando dados de um login bem-sucedido.
- **Enhanced Open**: criptografa o tráfego entre os dispositivos e o ponto de acesso, mesmo sem o uso de senha, aumentando a privacidade e a segurança em redes abertas.
- **Protocolos criptográficos atualizados**: substituem o [[AES CCM pelo modo de operação AES Galois Counter Mode (GCM)]]]. O Galois Counter Mode (GCM) apresenta níveis de desempenho superiores ao CCM.
- **Conexão fácil de Wi-Fi**, ou Wi-Fi Easy Connect, que permite conectar dispositivos digitalizando um código QR, reduzindo a necessidade de configurações complicadas e mantendo conexões seguras.

Nota:

O desempenho do Wi-Fi também depende do suporte do dispositivo aos padrões 802.11 mais recentes. A geração mais recente (802.11ax) está sendo comercializada como Wi-Fi 6. Os padrões anteriores foram nomeados retroativamente como Wi-Fi 5 (802.11ac) e Wi-Fi 4 (802.11n). Os padrões de desempenho são desenvolvidos em paralelo com as especificações de segurança do WPA. A maioria dos dispositivos Wi-Fi 6 e alguns produtos Wi-Fi 5 e Wi-Fi 4 devem suportar WPA3 nativamente ou com uma atualização de firmware/driver.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Para proteger uma rede, você deve confirmar que apenas usuários válidos estejam se conectando a ela. A autenticação de Wi-Fi está disponível em três tipos: pessoal, aberta e empresarial. Dentro da categoria pessoal, existem dois métodos: autenticação de chave pré-compartilhada (PSK) e autenticação simultânea de iguais (SAE).

Autenticação de chave pré-compartilhada

WPA2

No WPA2, a autenticação de [[pre-shared key (PSK)]] (Chave pré-compartilhada) usa uma senha para gerar a chave que é usada para criptografar as comunicações. Também é chamada de autenticação de grupo porque um grupo de usuários compartilha o mesmo segredo. Quando o access point é definido para o modo WPA2-PSK, o administrador configura uma senha entre 8 e 63 caracteres ASCII. Ela é convertida em um HMAC de 256 bits (expresso como um valor hexadecimal de 64 caracteres) usando o algoritmo de alongamento de chave PBKDF2. Esse HMAC é chamado de chave mestra em pares (Pairwise Master Key, PMK). O mesmo segredo deve ser configurado no ponto de acesso e em cada nó que ingressar na rede. A PMK é usada como parte da identificação mútua (handshake) de 4 vias do WPA2 para derivar várias chaves de sessão.

Nota:

Todos os tipos de autenticação pessoal de Wi-Fi mostraram ser vulneráveis a ataques que permitem ataques de dicionário ou força bruta contra a senha. A senha deve ter pelo menos 14 caracteres para mitigar os riscos de decifragem.

Autenticação pessoal WPA3

Embora o WPA3 ainda utilize uma frase secreta para autenticar estações no modo pessoal, ele altera o método que o segredo utiliza para negociar as chaves de sessão. O esquema usado é chamado de troca de chaves autenticada por senha (Password-Authenticated Key Exchange, PAKE). No WPA3, o protocolo Simultaneous Authentication of Equals (SAE) substitui o método de chave pré-compartilhada (PSK) do WPA2 para a criação da Pairwise Master Key (PMK). No entanto, o handshake de 4 vias ainda é utilizado para a troca de chaves após o estabelecimento da PMK. A SAE usa o handshake Dragonfly, que é basicamente um acordo de chaves Diffie-Hellman sobre curvas elípticas, combinado com um valor de hash derivado da senha e do endereço MAC do dispositivo para autenticar os nós. Com a SAE, não deve haver nenhuma maneira de um invasor detectar o handshake para obter o valor do hash e tentar usar uma força bruta offline ou um ataque de dicionário para recuperar a senha. O Dragonfly também implementa chaves de sessão efêmeras que fornecem sigilo encaminhado (forward secrecy).

Nota:

As interfaces de configuração dos pontos de acesso podem usar nomenclaturas diferentes para esses métodos. Você poderá ver WPA2-Personal e WPA3-SAE em vez de WPA2-PSK e WPA3-Personal, por exemplo. Além disso, um access point pode ser configurado apenas para WPA3 ou com suporte para WPA2 legado (modo WPA3-Personal Transition).

Pesquisadores identificaram falhas no WPA3-Personal quando configurado em Modo de Transição, o que permite ataques de downgrade para WPA2. ([wi-fi.org/security-update-april-2019](https://www.wi-fi.org/security-update-april-2019) (<https://www.wi-fi.org/security-update-april-2019>)).

Autenticação avançada

Os modos de [[autenticação empresarial]] wireless, como WPA2/WPA3-Enterprise, incluem diversos componentes essenciais desenvolvidos para aumentar a segurança das redes sem fio corporativas. Um elemento importante é a autenticação 802.1x, que fornece uma estrutura de controle de acesso à rede baseada em portas, garantindo que

apenas os dispositivos autenticados recebam acesso à rede. Normalmente, o 802.1x requer um servidor de autenticação, como o RADIUS (Remote Authentication Dial-In User Service ou serviço ao usuário de discagem de autenticação remota), que verifica as credenciais de usuários ou dispositivos que tentam se conectar à rede.

Nos esquemas de autenticação do modo corporativo, os usuários têm um conjunto exclusivo de credenciais, em vez da senha compartilhada usada no modo pessoal WPA2/WPA3. Exigir que cada usuário ou dispositivo seja autenticado usando credenciais exclusivas permite que os administradores de rede rastreiem o uso da rede em um nível granular. O protocolo também suporta vários tipos de protocolo de autenticação extensível (Extensible Authentication Protocol, EAP), como EAP-TLS, EAP-TTLS ou PEAP, que definem métodos de autenticação específicos. O EAP-TLS, por exemplo, usa certificados cliente-servidor para autenticação mútua, enquanto o EAP-TTLS e o PEAP utilizam um certificado do lado do servidor. O certificado do lado do servidor é usado para estabelecer um túnel seguro para transmitir credenciais de usuário e ajuda os dispositivos a validar a legitimidade do access point. A autenticação em modo corporativo inclui o gerenciamento dinâmico de chaves de criptografia, alterando automaticamente as chaves de criptografia usadas durante a sessão de um usuário.

Remote Authentication Dial-In User Service (RADIUS) (serviço de autenticação da Internet da Microsoft)

O padrão de serviço ao usuário de discagem de autenticação remota (RADIUS) é publicado como um padrão da Internet. Existem vários produtos RADIUS para servidor e cliente.

O dispositivo NAS (Network Access Server) é configurado com o endereço IP do servidor RADIUS e com um segredo compartilhado. Isso permite que o cliente seja autenticado no servidor. Lembre-se de que o cliente é o dispositivo de acesso (switch, access point ou gateway VPN), não o computador ou notebook do usuário. Um fluxo de trabalho de autenticação RADIUS genérico ocorre da seguinte forma:

1. O dispositivo do usuário (o requerente) faz uma conexão com o dispositivo NAS, como um access point, switch ou servidor de acesso remoto.
2. O NAS solicita ao usuário suas credenciais de autenticação.

O RADIUS suporta PAP, CHAP e EAP. A maioria das implementações agora usa o EAP, pois o PAP e o CHAP não são seguros. Se credenciais EAP forem exigidas, o NAS permite que o supplicant transmita dados [[EAP over LAN (EAPoL)]], mas não autoriza qualquer outro tipo de tráfego de rede.

3. O supplicant envia as credenciais como dados EAPoL.

O cliente RADIUS usa essas informações para criar um pacote RADIUS Access-Request criptografado usando o segredo compartilhado. Ele envia o Access-Request para o servidor AAA (Authentication, Authorization and Accounting) utilizando UDP na porta 1812 (por padrão).

4. O servidor AAA descriptografa a Access-Request usando o segredo compartilhado.

Se a Access-Request não puder ser descriptografada (por exemplo, porque o segredo compartilhado não está configurado corretamente), o servidor não responderá.

5. Com o EAP, haverá uma troca de pacotes para desafio de acesso (Access-Challenge) e solicitação de acesso (Access-Request) à medida que o método de autenticação é configurado e as credenciais verificadas.

O NAS atua como elemento de passagem (pass-thru), pegando mensagens RADIUS do servidor e encapsulando-as como EAPoL para transmiti-las ao requerente.

6. No final desta troca, se o requerente for autenticado, o servidor AAA responde com um pacote de acesso aceito (Access-Accept); caso contrário, retorna um pacote de acesso rejeitado (Access-Reject).

Opcionalmente, o NAS pode usar o RADIUS para contabilidade (registro). A contabilidade usa a porta 1813. O servidor de contabilidade pode ser diferente do servidor de autenticação.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O [[controle de acesso à rede (NAC)]] não apenas autentica usuários e dispositivos antes de permitir seu acesso à rede, mas também verifica e impõe a conformidade com as políticas de segurança estabelecidas. Ao avaliar a versão do sistema operacional, o nível do patch, o status do antivírus ou a presença de software de segurança específico, o NAC garante que os dispositivos atendam a um conjunto mínimo de padrões de segurança antes de receber acesso à rede.

O NAC também pode restringir o acesso com base no perfil do usuário, tipo de dispositivo, localização e outros atributos, para garantir que os usuários e dispositivos possam acessar apenas os recursos necessários para realizar suas funções. O NAC desempenha um papel crucial na identificação e quarentena de dispositivos suspeitos ou fora de conformidade. Para organizações com políticas que permitem levar o próprio dispositivo (Bring-Your-Own-Device, BYOD) e que fazem uso crescente de dispositivos de IoT, o NAC as ajuda a proteger seu ambiente de rede interno contra acessos não autorizados.

O NAC e as redes locais virtuais (Virtual Local Area Network, VLAN) trabalham juntos para melhorar e automatizar a segurança da rede. Uma das principais maneiras pelas quais o NAC se integra às proteções de VLAN é por meio da atribuição dinâmica de VLAN. A atribuição dinâmica de VLAN é um recurso do NAC que atribui uma VLAN a um dispositivo com base nos atributos de identidade do usuário, tipo de dispositivo, localização do dispositivo ou resultados da verificação de integridade. Por exemplo, um usuário visitante (como um fornecedor) pode ser colocado em uma VLAN que fornece apenas acesso à Internet, enquanto um usuário corporativo seria atribuído a uma VLAN com acesso a recursos internos. Além disso, o NAC pode interagir com VLANs dinâmicas para implementar procedimentos de

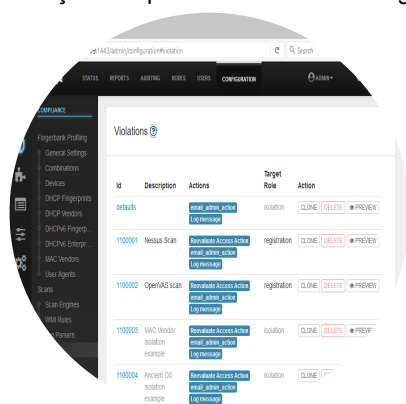
quarentena. Se um dispositivo não estiver em conformidade com as políticas de segurança — por exemplo, se não tiver software antivírus atualizado — o sistema NAC pode movê-lo automaticamente para uma VLAN de quarentena. Essa VLAN geralmente é isolada do resto da rede, limitando possíveis danos causados por ameaças como malware.

Agente vs. Configurações sem agente

O NAC pode aplicar políticas de segurança usando métodos baseados em agente e métodos sem agente. Em uma abordagem baseada em agente, um agente de software é instalado nos dispositivos que se conectam à rede. Esse agente se comunica com a plataforma NAC, fornecendo informações detalhadas sobre o status e o nível de conformidade do dispositivo. Uma implementação de NAC baseada em agente pode habilitar recursos como remediação automática, em que o agente de NAC pode executar ações como atualizar software ou desativar configurações específicas para deixar um dispositivo em conformidade com as configurações de segurança obrigatórias.

Em contraste, uma abordagem de NAC sem agente usa controle de acesso à rede baseado em porta ou varreduras de rede para avaliar os dispositivos. Por exemplo, o NAC sem agente pode usar a identificação digital individual (fingerprinting) de DHCP para identificar o tipo e a configuração de um dispositivo quando este se conecta, ou pode executar uma varredura de rede para detectar portas abertas ou serviços ativos. Embora os métodos sem agente possam não fornecer informações detalhadas sobre o status de um dispositivo, eles podem ser usados com qualquer dispositivo que se conecte à rede, incluindo dispositivos convidados ou de IoT, sem a necessidade de qualquer configuração preliminar.

Figura 1. Definição de violações de política no NAC de código aberto PacketFence.



(Captura de tela usada com permissão de) packetfence.org (<https://packetfence.org/>).

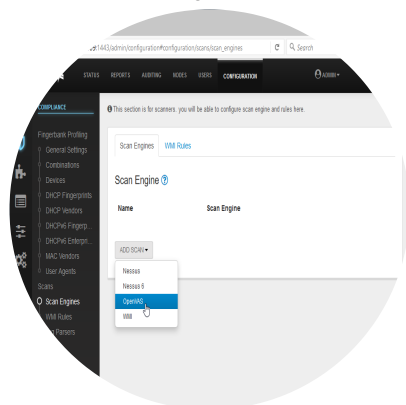
Descrição

As abas no topo são: status, relatórios, auditoria, nós, usuários e configuração (selecionada). O painel à esquerda está intitulado compliance, sob o qual a subopção violações está selecionada. O painel direito está intitulado violações. A tabela sob o título lista: Id, Descrição, Ações, Papel de Destino e Ação.

Um agente pode ser persistente, caso em que é instalado como um aplicativo de software no cliente, ou não persistente.

Um agente não persistente (ou dissolúvel) é carregado na memória durante a avaliação da postura, mas não está instalado no dispositivo.

Figura 2. O PacketFence permite o uso de várias técnicas de varredura, incluindo varreduras de vulnerabilidade, como Nessus e OpenVAS, consultas do Windows Management Instrumentation (WMI) e analisadores de log.



Captura de tela usada com permissão de packetfence.org (<https://packetfence.org/>).

Descrição

As abas no topo são: status, relatórios, auditoria, nós, usuários e configuração (selecionada). O painel à esquerda está intitulado compliance, sob o qual a subopção scan engines (em compliance) está selecionada. O painel à direita possui um ícone de informação no topo que exibe: esta seção é para scanners. Você poderá configurar o mecanismo de varredura e as regras aqui. Abaixo estão as abas scan engine (selecionada) e regras WMI. Sob o título scan engine estão os cabeçalhos: nome e scan engine. O menu suspenso adicionar varredura, na parte inferior, apresenta as seguintes opções: Nessus, Nessus 6, OpenVAS (selecionado) e WMI.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Firewalls, sistemas de detecção de intrusão (Intrusion Detection Systems, IDS), sistemas de prevenção de intrusão (Intrusion Prevention Systems, IPS) e filtros da Web são componentes fundamentais em uma infraestrutura de segurança cibernética projetada para proteger os sistemas em rede. Um firewall serve como a primeira linha de defesa em segurança de rede. Ele monitora e controla o tráfego de rede que entra e que sai com base em regras predeterminadas, criando efetivamente uma barreira entre uma rede interna confiável e redes externas não confiáveis.

Os sistemas de detecção de intrusão (IDS) e os sistemas de prevenção de intrusão (IPS) aprofundam ainda mais a segurança da rede. Um IDS monitora o tráfego de rede em busca de sinais de possíveis incidentes e alerta os administradores de sistemas quando essas atividades são detectadas. Um IPS, por outro lado, não apenas detecta, mas também evita ameaças identificadas tomando medidas automaticamente, como bloquear o tráfego de rede ou encerrar conexões.

Os filtros da Web complementam essas medidas de segurança controlando o acesso ao conteúdo da Internet. Eles impedem que os usuários acessem sites potencialmente mal-intencionados, bloqueiam o download de arquivos mal-intencionados e podem até monitorar e controlar o acesso a sites restritos. Eles são cruciais para prevenir infecções por malware, proteger dados confidenciais e manter a conformidade com políticas de uso aceitável. Quando combinadas, essas ferramentas fornecem uma defesa em camadas e aumentam a capacidade de uma organização de proteger sua rede e sistemas contra muitas ameaças.

Objetivos abordados no exame:

- 4.5 Considerando determinado cenário, modificar os recursos empresariais para aumentar a segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Uma lista de controle de acesso (Access Control List, ACL) enumera as permissões associadas a um dispositivo de rede que controla o tráfego ao nível da interface de rede, como um roteador ou um switch. As ACLs geralmente usam informações de pacote, como endereços IP de origem e destino, números de porta e o protocolo para decidir se devem permitir ou negar o tráfego. Elas são geralmente implementadas em dispositivos de rede para fornecer controle de tráfego em toda a rede, adicionando uma camada de segurança e eficiência. Em contraste, uma regra de firewall determina como os firewalls devem lidar com o tráfego que entra ou sai da rede quanto a endereços IP, intervalos de IP ou interfaces de rede específicos. Os firewalls geralmente fornecem controle da rede e dos aplicativos. Eles são criados para proteger um perímetro de rede, impedindo o acesso não autorizado à rede ou a partir dela. As regras de firewall podem se basear em vários fatores, como endereços IP, números de porta, protocolos ou até mesmo padrões de tráfego de aplicativos específicos.

As regras na ACL de um firewall são processadas de cima para baixo. Se o tráfego cumprir uma das regras, ele poderá passar; consequentemente, as regras mais específicas são colocadas no topo. A regra padrão final normalmente é bloquear qualquer tráfego que não tenha correspondido a uma regra ([[negação implícita]]). Se o firewall não tiver uma regra de negação implícita padrão, uma regra de negação explícita poderá ser adicionada manualmente ao final da ACL.

Figura 1. Exemplo de regras de firewall configuradas no IPFire. Esse conjunto de regras permite qualquer tráfego HTTP, HTTPS ou SMTP para endereços internos específicos.



Captura de tela usada com permissão do IPFire

Cada regra pode especificar se o tráfego deve ser bloqueado ou permitido com base em vários parâmetros, muitas vezes chamados de tuplas. Se imaginarmos que cada regra é como uma linha em um banco de dados, então as tuplas seriam as colunas. Por exemplo, na captura de tela anterior, as tuplas incluem Protocolo, Origem (endereço), (Origem) Porta, Destino (endereço), (Destino) Porta e assim por diante.

Até mesmo o firewall de filtragem de pacotes mais simples pode ser difícil de configurar de forma segura. É essencial criar uma política por escrito que descreva o que um conjunto de regras de filtragem deve fazer e testar a configuração o máximo possível para garantir que as ACLs configuradas funcionem conforme o esperado. Além disso, deve-se testar e documentar as alterações feitas nas ACLs. Alguns outros princípios básicos são:

- Bloquear solicitações recebidas de endereços IP internos ou privados (que foram claramente falsificados).
- Bloquear solicitações recebidas de protocolos que deveriam funcionar apenas na rede local, como ICMP, DHCP ou tráfego de protocolo de roteamento.
- Usar o teste de penetração para confirmar se a configuração é segura. Registrar as tentativas de acesso e monitorar os logs em busca de atividades suspeitas.
- Seguir as etapas usuais para proteger o hardware no qual o firewall está sendo executado e usar a interface de gerenciamento.

num	target	prot	opt	source	destination
1	DROP	all	--	10.1.0.192	0.0.0.0/0
2	ACCEPT	tcp	--	10.1.0.0/24	0.0.0.0/0 tcp dpt:22
3	ACCEPT	udp	--	0.0.0.0/0	0.0.0.0/0 udp dpt:53
4	ACCEPT	tcp	--	0.0.0.0/0	0.0.0.0/0 tcp dpt:53
5	ACCEPT	tcp	--	10.1.0.0/24	0.0.0.0/0 tcp dpt:80
	ACCEPT	tcp	--	10.1.0.0/24	0.0.0.0/0 tcp dpt:443
	all	--	--	0.0.0.0/0	0.0.0.0/0 ctstat*

Por exemplo, uma regra de firewall pode ser criada especificamente para permitir ou negar o tráfego com base nos números de porta TCP ou UDP em que um serviço opera. Se um servidor web em uma rede permitir apenas o tráfego HTTP e HTTPS recebido, as regras poderão ser configuradas para permitir o tráfego apenas nas portas 80 (HTTP) e 443 (HTTPS), as portas padrão para estes serviços. Da mesma forma, as regras podem ser definidas para restringir a entrada na rede de certos protocolos, como FTP ou SSH, se não forem necessários, reduzindo assim a possível superfície de ataque.

Além disso, você pode usar regras de firewall para restringir o tráfego de saída e evitar certos tipos de comunicação de dentro da rede. Por exemplo, uma regra pode bloquear todo o tráfego de saída para a porta 25 (SMTP) de modo a evitar que uma máquina comprometida na rede envie emails de spam.

Sub-rede filtrada

Uma sub-rede filtrada, também conhecida como rede perimetral, cria uma camada adicional de proteção entre a rede interna de uma organização e a Internet. Uma sub-rede filtrada atua como uma zona neutra, separando servidores expostos publicamente de recursos confidenciais da rede interna para reduzir a exposição dos recursos internos a ameaças externas. Em termos práticos, a sub-rede filtrada geralmente hospeda serviços web, email, DNS ou FTP. Normalmente, esses sistemas devem ser acessíveis a partir da Internet pública, mas isolados de sistemas internos confidenciais para limitar o impacto de uma violação de um desses serviços. Ao colocar esses servidores na sub-rede filtrada, uma organização pode limitar os danos se esses servidores forem comprometidos.

Os firewalls são normalmente usados para criar e controlar o tráfego de ida e volta da sub-rede filtrada. O primeiro firewall, entre a Internet e a sub-rede filtrada, é configurado para permitir o tráfego para os serviços hospedados na sub-rede filtrada. O segundo firewall, entre a sub-rede filtrada e a rede interna, é configurado para bloquear a maioria (praticamente todo) do tráfego da sub-rede filtrada para a rede interna. Uma sub-rede filtrada é parte fundamental da arquitetura de segurança de uma rede e um exemplo importante de segmentação de rede como um tipo de controle de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os sistemas de detecção de intrusão (IDS) e os sistemas de prevenção de intrusão (IPS) desempenham papéis cruciais nas operações de segurança. Ambos os sistemas monitoram o tráfego de rede, em busca de padrões ou atividades suspeitas que possam indicar uma intrusão na rede ou no sistema. No entanto, eles diferem em suas capacidades e respostas às ameaças percebidas.

Os sistemas de detecção de intrusão (IDS) baseados em host e em rede e os sistemas de prevenção de intrusão (IPS) oferecem vantagens exclusivas na proteção de uma rede, e o uso de ambos geralmente leva a uma postura de segurança mais robusta. Os IDS/IPS baseados em host (HIDS/HIPS) são instalados em sistemas ou servidores individuais para monitorar e analisar o comportamento e as configurações do sistema em busca de atividades suspeitas.

Os HIDS/HIPS são particularmente eficazes na identificação de ameaças internas, na detecção de alterações nos arquivos do sistema e no monitoramento de eventos fora da rede, como logins locais e processamentos do sistema. Isso os torna essenciais para proteger sistemas cruciais contra ameaças internas e externas.

OSSEC é uma solução HIDS de código aberto que realiza análise de log, verificação de integridade, monitoramento de registro do Windows, detecção de rootkit, alerta em tempo real e resposta ativa. É compatível com várias plataformas, incluindo Linux, Windows e macOS.

Soluções IDS/IPS baseadas em rede (NIDS/NIPS) monitoram o tráfego de rede. Eles procuram por padrões ou assinaturas de ameaças conhecidas e por comportamentos de pacotes de rede incomuns. Os NIDS/NIPS são eficazes na identificação e resposta a ameaças em vários sistemas, como ataques de negação de serviço distribuído (DDoS) ou atividades de varredura de rede.

Apesar de seus pontos fortes, nenhum tipo pode substituir totalmente o outro. Os HIDS/HIPS estão restritos às atividades no host em que estão instalados, portanto, não detectam efetivamente anomalias em toda a rede. Da mesma forma, os NIDS/NIPS não podem fornecer visibilidade detalhada das atividades específicas do host ou detectar ameaças que não envolvam tráfego de rede.

Exemplos de ferramentas IDS e IPS

Os sistemas de detecção de intrusão (IDS), como o Snort, são criados para detectar possíveis ameaças e gerar alertas.

Os sistemas IDS são passivos, inspecionam o tráfego da rede, identificam possíveis ameaças com base em regras predefinidas ou comportamentos incomuns e enviam alertas aos administradores. Eles não bloqueiam ou impedem ativamente as ameaças, mas notificam o possível problema. Isso permite que os analistas de segurança investiguem o alerta, evitando interrupções no tráfego de rede ou o possível bloqueio de tráfego legítimo causado por falsos-positivos.

Nota:

Uma excelente descrição e detalhamento das regras do Snort estão disponíveis em <https://snort.org/documents#OfficialDocumentation> (<https://snort.org/documents/snort-rule-infographic>).

Em contraste, os sistemas de prevenção de intrusão (IPS), como o Suricata, são ferramentas de segurança proativas, que detectam possíveis ameaças e tomam medidas para impedi-las ou mitigá-las. Um IPS identifica uma ameaça ao usar métodos semelhantes a um IDS e pode bloquear o tráfego da fonte ofensiva, descartar pacotes mal-intencionados ou redefinir conexões para interromper um ataque. Embora isso possa evitar danos imediatamente, há risco de falsos-positivos que levam ao bloqueio de tráfego legítimo.

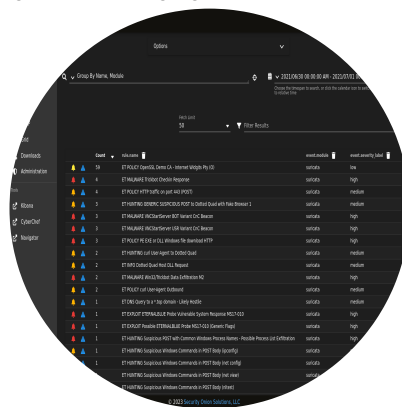
Ferramentas importantes de IDS e IPS:

- **Snort** é uma das ferramentas IDS mais conhecidas. Ele usa uma linguagem baseada em regras, que combina os benefícios de assinatura, protocolo e métodos de inspeção baseados em anomalias, oferecendo recursos robustos de detecção. A natureza de código aberto do Snort e sua ampla adoção resultaram em uma grande

comunidade contribuindo com regras e configurações, tornando-o uma ferramenta versátil para vários ambientes.

- **Suricata** é um mecanismo de IDS/IPS/NSM de código aberto de alto desempenho. O Suricata foi desenvolvido para aproveitar ao máximo o hardware moderno e oferecer maior desempenho e escalabilidade do que o Snort. O Suricata pode funcionar como um IDS ou um IPS e é compatível com os conjuntos de regras do Snort, tornando-o uma opção altamente flexível para a segurança de rede.
- **Security Onion** é uma distribuição Linux desenvolvida para detecção de intrusão, monitoramento de segurança da rede e gestão de logs. Inclui o Snort e o Suricata, além de uma série de outras ferramentas, para fornecer uma plataforma completa de segurança de rede. Essa integração fornece uma visão holística da atividade da rede, permitindo que os administradores correlacionem dados de diferentes ferramentas e obtenham uma compreensão abrangente da postura de segurança da rede.

Figura 1. Painel de Alertas Security Onion exibindo vários alertas captados usando o conjunto de regras de Ameaças Emergentes (Emerging Threats, ET) e Suricata.



Captura de tela usada com permissão da Security Onion.

Descrição

A opção Alerts está selecionada no painel à esquerda. O painel direito, intitulado Alerts (Total found: 102), exibe a barra de busca com um menu suspenso que lê: Group by name, Module. Outro menu suspenso à direita permite aos usuários escolher o intervalo de tempo. O limite de busca está definido como 50. Os resultados filtrados são exibidos em uma tabela com as colunas: count, rule.name, event.module e event.security label.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Em um IDS, o mecanismo de análise é o componente que verifica e interpreta o tráfego captado pelo sensor com o objetivo de identificar tráfego suspeito. O mecanismo de análise determina a classificação de um evento com opções típicas de ignorar, registrar apenas, alertar e bloquear (IPS). Um conjunto de regras programadas conduz o processo de tomada de decisão do mecanismo de análise. Existem vários métodos para formular o conjunto de regras.

Detecção baseada em assinatura

A [[detecção baseada em assinaturas]] (ou correspondência de padrões) significa que o mecanismo é carregado com um banco de dados de padrões ou assinaturas de ataques. Se o tráfego corresponder a um padrão, o mecanismo gera um incidente.

Figura 1. Arquivo de regras Snort fornecido pelo feed da comunidade de ameaças emergentes de código aberto.

[illegible]

Descrição

A tela exibe: Begin ET – Emerging – ActiveX Rules Category, Begin GID: 1 Based Rules, seguido pelos alertas. O texto na parte inferior diz: 27185 linhas (aviso: sem permissão de gravação).

As assinaturas e regras (geralmente chamadas de plug-ins ou feeds) que alimentam a detecção de intrusões precisam ser atualizadas regularmente para fornecer proteção contra os tipos mais recentes de ameaças. Os softwares comerciais exigem uma assinatura paga para obter as atualizações. É importante configurar o software para se atualizar apenas a partir de repositórios válidos, de preferência usando um método de conexão seguro, como HTTPS.

Detecção baseada em comportamento e anomalia

A detecção baseada em comportamento significa que o mecanismo é treinado para reconhecer o tráfego ou os eventos considerados como “normais”. Qualquer coisa que se afaste desse padrão (fora de um nível de tolerância definido) gera um incidente. O software será capaz de identificar ataques zero-day, ameaças internas e outras atividades maliciosas para as quais não existe uma assinatura específica.

Historicamente, [[produtos de detecção de comportamento e anomalias de rede (NBAD)]] oferecem esse tipo de detecção. Um mecanismo NBAD utiliza [[heurísticas]] (ou seja, aprende com a experiência) para gerar um modelo estatístico de como é o tráfego normal de referência (baseline). Pode criar vários perfis para modelar o uso da rede em

diferentes horários do dia. Isso implica que o sistema gera falsos-positivos e falsos-negativos até ter tempo de melhorar seu modelo estatístico do que é “normal”. Um “false positive” ocorre quando um comportamento legítimo gera um alerta, enquanto um falso-negativo ocorre quando a atividade mal-intencionada não gera um alerta.

Embora os produtos NBAD fossem relativamente simples, o uso de aprendizagem de máquina em produtos mais recentes os tornou mais produtivos. Conforme identificado pela análise de mercado da Gartner ([gartner.com/en/documents/3917096/market-guide-for-user-and-entity-behavior-analytics](https://www.gartner.com/en/documents/3917096/market-guide-for-user-and-entity-behavior-analytics)), existem duas classes gerais de produtos de detecção baseada em comportamento que utilizam machine learning:

- **Análise de comportamento de usuários e entidades (UEBA)** — são produtos que analisam indicadores provenientes de múltiplas fontes de detecção de intrusões e logs para identificar anomalias. Eles geralmente são integrados a plataformas de gerenciamento de eventos e informações de segurança (SIEM).
- **Análise de tráfego de rede (NTA)**: são produtos semelhantes a IDS e NBAD, pois aplicam técnicas de análise exclusivamente aos fluxos de rede, em vez de utilizar múltiplas fontes de dados de rede e logs.

Muitas vezes, a detecção baseada em comportamentos e a detecção baseada em anomalias são consideradas a mesma coisa (no sentido de que o mecanismo detecta comportamento anômalo). Contudo, isso nem sempre é verdade. A detecção baseada em anomalias também pode se referir à procura específica de irregularidades no uso de protocolos. Por exemplo, o mecanismo pode verificar cabeçalhos de pacotes ou a troca de pacotes em uma sessão em relação aos padrões RFC e gerar um alerta se eles se desviarem da conformidade estrita com a RFC.

Análise de tendências

A [análise de tendências] é um aspecto fundamental na gestão de sistemas de detecção (IDS) e prevenção de intrusões (IPS), pois auxilia na compreensão do ambiente ao longo do tempo, ajudando a identificar padrões, anomalias e ameaças potenciais. Os analistas de segurança podem identificar padrões e tendências que indicam ameaças contínuas ou crescentes ao rastrear eventos e alertas. Por exemplo, um aumento nos alertas relacionados a um ataque específico pode sugerir que uma rede está sendo alvo de ataque ou que uma vulnerabilidade está sendo explorada ativamente. As tendências também podem ajudar a ajustar os sistemas IDS/IPS. Com o tempo, os analistas de segurança podem identificar falsos-positivos ou alertas desnecessários que aparecem com frequência. Esses alertas podem ser ajustados para que os analistas se concentrem em alertas mais importantes.

Os dados de tendências podem contribuir para as estratégias de segurança operacional ao identificar ameaças comuns e sistemas frequentemente alvejados. Essa estratégia destaca áreas frágeis que precisam de atenção, seja por meio de mudanças na política de segurança ou investimento em ferramentas e treinamentos adicionais de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O [[filtro de acesso à web]] é essencial para as operações de cibersegurança, desempenhando um papel fundamental na proteção da rede de uma organização. Sua principal função é impedir que os usuários acessem sites mal-intencionados ou inadequados, protegendo assim a rede de possíveis ameaças. A filtragem web analisa o tráfego dos sites, geralmente em tempo real, e pode restringir o acesso com base em vários critérios, como URL, endereço IP, categoria de conteúdo ou até mesmo palavras-chave específicas.

Um dos principais benefícios dela é a prevenção de malware, incluindo ataques de ransomware e phishing, que muitas vezes se originam em sites mal-intencionados. Ao restringir o acesso a esses sites, a filtragem web reduz significativamente o risco de infecções por malware. Ela também pode aumentar a produtividade dos funcionários e limitar a responsabilidade legal, impedindo o acesso a conteúdo inadequado ou não relacionado ao trabalho. Ela desempenha um papel fundamental nas estratégias de prevenção de perda de dados (DLP) ao bloquear certos tipos de transferência de dados ou o acesso a sites conhecidos por vazamento de dados.

Filtragem baseada em agentes

A filtragem baseada em agentes envolve a instalação de um agente de software em desktops, notebooks e dispositivos móveis. Os agentes impõem a conformidade com as políticas de filtragem web da organização. Eles se comunicam com um servidor de gestão centralizado para recuperar as políticas e regras de filtragem e depois aplicá-las localmente no dispositivo. As soluções baseadas em agentes geralmente utilizam plataformas de nuvem para garantir que possam se comunicar com dispositivos, independentemente da rede à qual estão conectados. Portanto, as políticas de filtragem permanecem em vigor mesmo quando os usuários estão fora da rede corporativa, como quando trabalham em casa ou viajando.

A filtragem baseada em agentes também pode fornecer relatórios e análises detalhados. O agente pode registrar as tentativas de acesso à web e retornar esses dados a um servidor de gestão para análise, permitindo que os analistas de segurança monitorem os padrões de uso da Internet, identifiquem as tentativas de acesso ao conteúdo bloqueado e ajustem as regras de filtragem, conforme necessário. Como a filtragem ocorre localmente no dispositivo, os métodos baseados em agentes geralmente fornecem um controle mais detalhado, como filtrar o tráfego HTTPS ou aplicar regras de filtragem diferentes para diferentes aplicativos.

Filtragem web centralizada

Um servidor proxy centralizado desempenha um papel fundamental na filtragem de conteúdo da web ao atuar como um intermediário entre os usuários finais e a Internet. Quando uma organização roteia o tráfego da Internet por meio de um servidor proxy centralizado, ela pode controlar e monitorar de forma eficaz todo o conteúdo da web de entrada e saída. A principal função do proxy na filtragem de conteúdo da web é analisar as solicitações web dos usuários e determinar se deve permitir ou negar o acesso com base nas políticas estabelecidas. O proxy pode bloquear o acesso a URLs específicos, endereços IP ou categorias de sites, como plataformas de redes sociais, sites de jogos de azar ou sites conhecidos por distribuir malware.

Além de bloquear conteúdo indesejado ou prejudicial, um servidor proxy centralizado consegue realizar registros em log e relatórios detalhados da atividade da web para que os analistas de segurança rastreiem e analisem os padrões de uso da Web, identifiquem violações de políticas e coletem informações valiosas para refinar as políticas e regras de filtragem. Um servidor proxy centralizado pode fornecer benefícios de segurança adicionais, como anonimizar solicitações e armazenar em cache o conteúdo da web para melhorar o desempenho.

Um servidor proxy centralizado emprega várias técnicas para proteger o tráfego da web e garantir a segurança da rede de uma organização:

- **Verificação de URL:** onde o servidor proxy examina os URLs solicitados pelos usuários. O filtro pode bloquear o acesso a URLs específicas conhecidas por hospedar conteúdo malicioso, ser inadequadas ou violar a política de uso da Internet da empresa.
- **Categorização de conteúdo:** classifica os sites em várias categorias, como redes sociais, jogos de azar, conteúdo adulto, webmail e muitos outros. As organizações podem definir regras para permitir ou negar o acesso com base nessas categorias, fornecendo uma maneira flexível de aplicar as políticas de uso da web.
- **Regras de bloqueio:** usa o servidor proxy para implementar regras de bloqueio com base em vários fatores, como URL do site, domínio, endereço IP, categoria de conteúdo ou até mesmo palavras-chave específicas no conteúdo da web. Por exemplo, uma organização pode bloquear todos os downloads .exe para evitar o download acidental de arquivos potencialmente prejudiciais.
- **Filtragem baseada em reputação:** usa servidores proxy para incorporar a filtragem baseada em reputação, pautada pelos bancos de dados continuamente atualizados que classificam os sites com base em seu comportamento e histórico observados. Sites conhecidos por hospedar malware, se envolver em ataques de phishing ou distribuir spam, por exemplo, costumam ter uma pontuação de reputação ruim e podem ser bloqueados automaticamente.

Figura 1. As categorias de conteúdo da filtragem web usam o firewall de código aberto IPFire.



Captura de tela usada com permissão do IPFire.

Descrição

As abas no topo são: sistema, status, rede, serviços, firewall, IPFire e logs. A tela lista as categorias de bloqueio sob o título configurações do filtro de URL. As categorias são as seguintes: ads, arjel, bank, chat, cryptojacking, dialer, drugs, filehosting, games, liste blanche, manga, phishing, publicite, remote-control, shortener, tricheur, warez, adult, associations religieuses, bitcoin, child, dangerous material, doh, educational games, financial, hacking, liste bu, marketingware, porn, radio, sect, social networks, strict redirector, update, webmail, aggressive, astrology, blog, cleaning, dating, download, examen pix, forums, jobsearch, mail, press, reaffected, sexual education, special, strong redirector, violence, agressif, audio-video, celebrity, cooking, ddos, drogue, exceptions liste bu, gambling, lingerie, malware, mobile-phone, proxy, redirector, shopping, sports, translation e vpn. Há uma caixa de seleção para cada categoria.

Problemas relacionados à filtragem web

A filtragem de conteúdo não está livre de possíveis problemas e desafios. Um problema comum é o bloqueio excessivo ou insuficiente. O bloqueio excessivo ocorre quando o filtro é muito restritivo, bloqueando inadvertidamente o acesso a sites legítimos e úteis e afetando negativamente a produtividade dos funcionários. O bloqueio insuficiente, por outro lado, ocorre quando o filtro permite o acesso a sites potencialmente prejudiciais ou inadequados. Outro problema é a gestão do tráfego criptografado (HTTPS). Sem a configuração adequada, os filtros da web podem ser incapazes de inspecionar o tráfego criptografado, que representa a maior parte do tráfego web moderno.

Descriptografar e inspecionar o tráfego HTTPS também levanta questões e preocupações com a privacidade dos funcionários. As preocupações com a privacidade podem surgir do registro em log e do monitoramento da atividade na web. Embora esses recursos sejam essenciais para a segurança e a aplicação das políticas, eles devem ser gerenciados com cuidado para proteger a privacidade do usuário e cumprir as leis e os regulamentos relevantes.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

O aprimoramento dos recursos de segurança da rede é essencial para proteger dados confidenciais, manter a integridade e disponibilidade dos sistemas de TI e suplementar os recursos das operações de segurança. Além disso, os requisitos legais, contratuais e regulatórios determinam padrões de segurança específicos, e a não conformidade resulta em penalidades substanciais.

Diretrizes para aprimorar os recursos de segurança da rede

Siga estas diretrizes para aprimorar os recursos de segurança da rede:

- Selecione um padrão seguro com base na análise cuidadosa do perfil de risco da organização.
- Automatize a implantação e gestão de padrões seguros usando ferramentas como Active Directory Group Policy, Ansible, Puppet ou Chef.
- Realize auditorias contínuas nas redes wireless para garantir a configuração adequada e validar os access points.
- Implemente métodos de autenticação de rede corporativa para aprimorar o registro em log, reforçar a proteção de dados e oferecer controle detalhado.
- Imponha requisitos de segurança de rede por meio da implementação de “controladores de acesso” (gatekeepers) do NAC.
- Use firewalls, IDS/IPS e filtragem web para monitorar e controlar o tráfego de rede e bloquear o acesso a conteúdos mal-intencionados ou inadequados.



This content is only available on larger screen sizes. Please revisit this page on a larger device.